Template for feedback to CEN 40000-1-1

Organization/individual	OpenSSF
Contacts	mneag@contractor.linuxfoundation.org; dwheeler@linuxfoundation.org
Date	8-Dec-25
Other relevant info	this is a complementary information resource to the PDF shared in a previous submission to ease the tracking

Item number	Type of comment (editorial, technical, remark)	Comments	Proposed change
Terms and definitions	technical	We would propose to add also the glossary of NIST: https://csrc.nist.gov/glossary We could add also the one from and the one from ISACA: https://www.isaca.org/resources/glossary?gad_source=1&gad_campaignid=21147302543&gbraid=0AAAAAD_A9K8VcD_9iEG9sq5V4gbmxtgSA&gclid=CjwKCAiAraXJBhBJEiwAjz7MZQ2z1GEV7sgByI_gmI0Fps9lhbaEOVX9lURrDDn-zSbzdXLRZuPbTBoCkcIQAvD_BwE	Include the two references also. You could also add them in the bibliography
3.8. the definition of integrity	technical	The current definition of integrity is a poor and inappropriate one. This definition "property of accuracy and completeness" is from an official source, but it's not focused on security and it fails to appropriately pair with this document's definition of "confidentiality". Background: We consulted the various definitions of "integrity" used by various NIST documents at: https://csrc.nist.gov/glossary/term/integrity. We found that NIST SP 800-152 defines integrity as "A property whereby data has not been altered in an unauthorized manner since it was created, transmitted, or stored." and NIST SP 800-175A defines it as "The property that protected data has not been modified or deleted in an unauthorized and undetected manner." Similarly, ISACA's glossary at https://www.isaca.org/resources/glossary?gad_source=1&gad_campaignid=21147302543&gbraid=0AAAAAD_A9K8VcD_9iEG9sq5V4gbmxtgSA&gclid=CjwKCAiAraXJBhBJEiwAjz7MZQ2z1GEV7sgByI_gmI0Fps9lhbaEOVX9lURrDDn-zSbzdXLRZuPbTBoCkcIQAvD_BwE defines integrity as "The guarding against improper information modification or destruction. This includes ensuring information nonrepudiation and authenticity." All these definitions emphasize that in cybersecurity, integrity is lost when there's an unauthorized modification/deletion. It's not about accuracy or completeness in the sense of a universal truth. We consulted this document's definition of "confidentiality" which is "property that information is not made available or disclosed to unauthorized individuals, entities, or processes" and tweaked those definitions to match. We think it's important that the definitions of integrity and confidentiality be clearly paired.	Our proposed alternative, based on this document's definition of "confidentiality", would be "property that information is not modified or destroyed by unauthorized individuals, entities, or processes"
3.9 the definition of likelihood	technical	we would prefer an enhnaced definition for likelihood	We would prefer a modified definition based on NIST SP 800-30 Rev. 1, changing "subjective" to "possibly-subjective" (since it's not always subjective) and changing "threat" to "threat agent" (since "threat" has many different meanings), resulting in this: "A weighted factor based on a possibly-subjective analysis of the probability that a given threat agent is capable of exploiting a given vulnerability or a set of vulnerabilities."
3.10 the definition of online hosting location	technical	the current definition is not accurate. Also, we do not think it is ok to see the term defined in the definition.	We would propose the next definition: "Any internet-accessible environment, server, service, platform, or infrastructure where digital assets are stored, processed, or made available to users."
3.11 the definition for Product control	technical	This definition of "product control" ("Measure on a product that is modifying risk") is used by some but it's extremely ambiguous in English. Does this mean the reader is to "measure" a product (like with a ruler), or is the reader supposed to impose a mechanism to reduce risk? Also, this definition only says we "modify" the risk, and that can't be correct. If we increase the likelihood or increase the negative impact, by this definition it would still be a control. A product control might be imposed on the product itself, but it might also be imposed its development processes, documentation, or other factors, so clearly it's not just a "measure on a product".	Here's a proposed definition for "product control" that builds on several existing definitions: "The set of processes, safeguards, and governance mechanisms used to ensure that a product's features, configurations, data handling, and operational behavior comply with security requirements throughout its lifecycle."
3.12 the definition of the remediation	technical	in our view, that is not clear and precise enough.	We would propose the NIST SP 800-216's definition: The neutralization or elimination of a vulnerability or the likelihood of its exploitation. ISACA has another good definition "Actions taken to mitigate or eliminate a vulnerability after it has been identified and assessed"

3.14 the definiition of residual cybersecurity risk and residual risk	technical	We would prefer to maintain only residual cybersecurity risk and to remove residual risk. Residual risk may be too general.	And we would prefer another definition from NIST (NIST SP 800-30 Rev. 1), slightly adapted - “Portion of cybersecurity risk remaining after security measures have been applied.” The word cybersecurity has been added. ISACA is clearly differentiating between residual risk and residual cybersecurity risk and has another good definition: “The remaining probability of an event occurring and its consequence that still exists after a risk response has been implemented”
3.15 the definition of security objective and cybersecurity objective	technical	We would prefer to keep only one notion - the cybersecurity objective.	remove the security objective
3.16 the defition of software package	technical	Software package - we would prefer to not find the term that should be defined in the definition itself.	An alternative could be “A software package is a bundled collection of computer programs, files, documentation, and all other components that are necessary for it to work” - this is taken from NordVPN glossary, but it makes more sense for us than the existing definition. Or stay with the definition of software from CRA legal text: ‘software’ means the part of an electronic information system which consists of computer code. The latter case would mean that this is removed as it was clear that we shall not repeat the definition from the legal text.